

ICO Data Protection Guidance

Right of Access

Under Article 15 of the UK GDPR, individuals have the right to obtain confirmation of whether or not their personal data is being processed, and if so, to request access to that personal data. This is known as a Subject Access Request (SAR). Organisations must respond to SARs within one calendar month of receipt.

Data Retention

Personal data must not be kept for longer than is necessary for the purpose for which it was collected. Organisations should have a clear retention schedule that sets out how long different categories of data are kept and the criteria used to determine retention periods. The ICO recommends reviewing retention schedules annually.

Lawful Basis for Processing

Article 6 of the UK GDPR requires that all processing of personal data must have a lawful basis. The six lawful bases are: consent, contract, legal obligation, vital interests, public task, and legitimate interests. Organisations must identify their lawful basis before processing begins and document it in their privacy notice.

Data Protection Officer

Some organisations are required to appoint a Data Protection Officer (DPO). This includes public authorities, organisations that carry out large-scale systematic monitoring of individuals, and organisations that process special category data on a large scale. The DPO must be given the resources necessary to carry out their tasks.